Sujet examen Semestre 1: Projet 1- Conception et développement d'applications sécurisées

Durée : 3 heures
Documents autorisés : Aucun
Matériel autorisé : Calculatrice simple
Barème : /100 points

Instructions générales :

- Écrivez du code clair et commenté
- Lisez attentivement toutes les consignes avant de commencer
- Gérez les cas limites et les erreurs
- Répondre directement sur les espaces réservés pour les réponses

Nom(s) et Prénom(s) : _____

Date : _____

PARTIE 1 : QUESTIONS DE COURS (30 points)

Répondez de manière simple et claire.

Question 1 (5 points)

Que signifie le sigle SDLC? Citez les 5 phases du cycle de vie d'un projet logiciel. Pour chaque phase, donnez l'objectif en UNE phrase.

Exemple attendu :

- Phase 1 : Analyse - Objectif : Comprendre les besoins

Votre réponse : (1 point = Phase + objectif)

Phase 1 : _____ (0.5 pt)

Objectif : _____ (0.5 pt)

GREEN UP ACADEMY

Phase 2 : _____ (0.5 pt)

Objectif : _____ (0.5 pt)

Phase 3 : _____ (0.5 pt)

Objectif : _____ (0.5 pt)

Phase 4 : _____ (0.5 pt)

Objectif : _____ (0.5 pt)

Phase 5 : _____ (0.5 pt)

Objectif : _____ (0.5 pt)

Question 2 (5 points)

Un Sprint en Scrum dure combien de temps ? Citez 2 événements (réunions) qui ont lieu pendant un Sprint et expliquez leur but en 1 phrase chacun.

Votre réponse :

Durée d'un Sprint : _____ **(1 point)**

Événement 1 : _____ **(1 point)**

But : _____ **(1 point)**

Événement 2 : _____ **(1 point)**

But : _____ **(1 point)**

GREEN UP ACADEMY

Question 3 (5 points)

Quelle est la différence entre? :

- **Authentification** : "Qui êtes-vous ?"
- **Autorisation** : "Que pouvez-vous faire ?"

Donnez UN exemple simple pour chacun.

Votre réponse :

Authentification : **(2.5 points)**

Définition : _____ (2 pts)

Exemple : _____ (0.5 pt)

Autorisation : **(2.5 points)**

Définition : _____ (2 pts)

Exemple : _____ (0.5 pt)

Question 4 (5 points)

Qu'est-ce que le principe "Secure by Design" ? Citez 2 exemples de bonnes pratiques.

Votre réponse :

Définition de Secure by Design : **(2 points)**

GREEN UP ACADEMY

Bonne pratique 1 : **(1.5 points)**

Bonne pratique 2 : **(1.5 points)**

Question 5 (5 points)

Qu'est-ce que l'injection SQL ? Pourquoi est-elle dangereuse ?

Votre réponse :

Définition de l'injection SQL : **(2.5 points)**

Explication sur sa dangerosité : **(2.5 points)**

Question 6 (5 points)

Citez 2 vulnérabilités de l'OWASP Top 10 et expliquez chacune en 1 phrase.

Votre réponse :

Vulnérabilité 1 : _____ **(1.5 points)**

Explication : _____ **(1 point)**

Vulnérabilité 2 : _____ **(1.5 points)**

Explication : _____ **(1 point)**

PARTIE 2 : QCM (30 points)

Cochez UNE ou Plusieurs bonnes réponses. Chaque question vaut 1,5 point.

Question 0

Quelle méthode de gestion de projet favorise les itérations courtes ?

- ☐ A) Cycle en cascade
- ☐ B) Méthode Agile/Scrum
- ☐ C) Méthode V
- ☐ D) Méthode séquentielle

Question 1

La méthode Agile permet :

- ☐ A) De changer les exigences en cours de projet
- ☐ B) De ne jamais faire de tests
- ☐ C) De livrer régulièrement des fonctionnalités
- ☐ D) De ne pas planifier

Question 2

Le Product Owner est responsable de :

- ☐ A) Écrire tout le code
- ☐ B) Gérer et prioriser le Product Backlog
- ☐ C) Animer le Daily Stand-up
- ☐ D) Tester l'application

Question 3

Un Sprint dure généralement :

- ☐ A) 1 jour
- ☐ B) 2 semaines
- ☐ C) 6 mois
- ☐ D) 1 an

Question 4

Les Story Points mesurent :

- ☐ A) Le nombre d'heures exactes
- ☐ B) La complexité relative d'une tâche
- ☐ C) Le nombre de bugs
- ☐ D) Le coût en euros

Question 5

Un mot de passe sécurisé doit être :

- ☐ A) Stocké en clair dans la base de données
- ☐ B) Hashé avec un algorithme comme bcrypt
- ☐ C) Partagé avec l'équipe
- ☐ D) Au minimum de 8 caractères avec complexité

GREEN UP ACADEMY

Question 6

HTTPS protège :

- ☐ A) Les données quand elles voyagent sur Internet
- ☐ B) Les données stockées dans la base de données
- ☐ C) Le code source
- ☐ D) Les serveurs

Question 7

Pour hasher un mot de passe, on utilise :

- ☐ A) MD5
- ☐ B) bcrypt
- ☐ C) Aucun algorithme (stocker en clair)
- ☐ D) Argon2

Question 8

Pour la gestion de projet Agile, on utilise :

- ☐ A) Jira
- ☐ B) Trello
- ☐ C) PowerPoint
- ☐D) Notepad

Question 9

Le RGPD concerne :

- ☐ A) La protection des données personnelles
- ☐ B) Seulement les grandes entreprises
- ☐ C) Le droit à l'effacement des données
- ☐ D) Uniquement les sites français

Question 10

Pour éviter l'injection SQL, il faut :

- ☐ A) Utiliser des requêtes préparées
- ☐ B) Concaténer les variables
- ☐ C) Valider les entrées utilisateur
- ☐ D) Ne rien faire

Question 11

Un Burndown Chart montre :

- ☐ A) Le travail restant dans un sprint
- ☐ B) Les bugs trouvés
- ☐ C) Le nombre de développeurs
- ☐ D) Le budget du projet

Question 12

La triade CIA en sécurité représente :

- ☐ A) Confidentialité, Intégrité, Disponibilité
- ☐ B) Code, Internet, Application
- ☐ C) Contrôle, Isolation, Autorisation
- ☐ D) Central Intelligence Agency

Question 13

Git permet de :

- ☐ A) Gérer les versions du code source
- ☐ B) Revenir à une version précédente du code
- ☐ C) Travailler en équipe sur le même projet
- ☐ D) Compiler automatiquement le code

Question 14

Un "commit" en Git signifie :

- ☐ A) Enregistrer les modifications localement
- ☐ B) Envoyer le code sur le serveur
- ☐ C) Supprimer des fichiers
- ☐ D) Télécharger le code depuis GitHub

Question 15

GitHub est :

- ☐ A) Un langage de programmation
- ☐ B) Une plateforme d'hébergement de code Git
- ☐ C) Un outil de gestion de projet
- ☐ D) Un système d'exploitation

Question 16

La commande "git pull" permet de :

- ☐ A) Récupérer les modifications depuis le dépôt distant
- ☐ B) Envoyer ses modifications vers GitHub
- ☐ C) Créer une nouvelle branche
- ☐ D) Supprimer un fichier

Question 17

Une "branche" (branch) en Git sert à :

- ☐ A) Développer une fonctionnalité isolément
- ☐ B) Travailler sur plusieurs versions en parallèle
- ☐ C) Supprimer du code
- ☐ D) Compiler le projet

Question 18

XSS (Cross-Site Scripting) permet d'injecter :

- ☐ A) Des scripts malveillants dans une page web
- ☐ B) Des virus dans le serveur
- ☐ C) Du code SQL dans la base
- ☐ D) Rien de dangereux

Question 19

La vélocité d'une équipe est :

- ☐ A) Le nombre de points réalisés par sprint
- ☐ B) La vitesse du serveur
- ☐ C) Le temps de réunion
- ☐ D) Le nombre de développeurs

PARTIE 3 : EXERCICES PRATIQUES (40 points)

Exercice 1 : Planification de Sprint (15 points)

Contexte simple : Vous avez une équipe de 3 développeurs. Votre équipe réalise en moyenne **20 points par sprint** (2 semaines).

Product Backlog :

ID	User Story	Points	Priorité
US1	Créer un compte utilisateur	3	Haute
US2	Se connecter	3	Haute
US3	Ajouter un produit au panier	5	Haute
US4	Payer en ligne	8	Moyenne
US5	Voir l'historique des commandes	5	Basse

US6	Laisser un avis	5	Basse

Questions :

a) (6 points) Quelles User Stories mettez-vous dans le prochain sprint ?

- Listez les US choisies **(3 points)**
- Calculez le total de points **(2 points)**
- Expliquez pourquoi vous avez fait ce choix (2-3 phrases) **(1 point)**

Votre réponse :

User Stories sélectionnées :

- ☐ US1 - Créer un compte utilisateur (3 points)
- ☐ US2 - Se connecter (3 points)
- ☐ US3 - Ajouter un produit au panier (5 points)
- ☐ US4 - Payer en ligne (8 points)
- ☐ US5 - Voir l'historique des commandes (5 points)
- ☐ US6 - Laisser un avis (5 points)

Total de points sélectionnés : ____ points

Justification de votre choix :

_____

_____

_____

_____

_____

_____

b) (4 points) Dans quel ordre allez-vous développer ces US ? Expliquez pourquoi cet ordre.

Votre réponse :

Ordre de développement : **(2 points)**

1. **US___ : _____**
2. **US___ : _____**
3. **US___ : _____**
4. **US___ : _____**

Explication de l'ordre choisi : **(2 points)**

c) (5 points) Vous êtes au milieu du sprint (1 semaine passée). Vous avez fait seulement 5 points sur 20. - Est-ce un problème ? Pourquoi ? - Que devez-vous faire ? (2 actions concrètes)

Votre réponse :

Est-ce un problème ? Pourquoi ? **(2 points)**

Action 1 à faire : **(1.5 points)**

Action 2 à faire : **(1.5 points)**

Exercice 2 : Trouver les erreurs de sécurité (12 points)

Voici un code simple avec des problèmes :

```
# Code pour se connecter
@app.route('/login', methods=['POST'])
def login():
    username = request.form['username']
    password = request.form['password']

    # Recherche dans la base de données
    query = "SELECT * FROM users WHERE username='" + username + "'"
    user = database.execute(query)

    if user and user.password == password:
        return "Bienvenue !"
    else:
        return "Erreur de connexion"
```

Questions :

a) (6 points) Trouvez **2 problèmes de sécurité** dans ce code. Pour chaque problème :

- Quel est le problème ? (nom de la vulnérabilité)
- Pourquoi c'est dangereux ? (1 phrase)
- Comment un attaquant peut l'exploiter ? (1 exemple simple)

Exemple de réponse attendue :

Problème (exemple) :

Nom de la vulnérabilité : **Absence de validation des entrées utilisateur**

Pourquoi c'est dangereux : L'application accepte n'importe quelle donnée sans vérifier si elle est valide ou malveillante

Exemple d'exploitation : Un attaquant peut envoyer des caractères spéciaux ou des scripts pour tenter de compromettre le système.

Votre réponse :

Problème 1 : **(3 points)**

Nom de la vulnérabilité : _____ (1 pt)

Pourquoi c'est dangereux : _____ (1 pt)

_____

_____

Exemple d'exploitation : _____ (1 pt)

_____

_____

Problème 2 : **(3 points)**

Nom de la vulnérabilité : _____ (1 pt)

Pourquoi c'est dangereux : _____ (1 pt)

_____

_____

Exemple d'exploitation : _____ (1 pt)

_____

_____

_____

b) (6 points) choisissez le code corrigé qui résout ces 2 problèmes.

Parmi les 3 versions de code ci-dessous, choisissez celle qui corrige TOUS les problèmes de sécurité :

_____

Version A

```
import bcrypt

@app.route('/login', methods=['POST'])
```

```python
def login():
    username = request.form['username']
    password = request.form['password']

    # Recherche dans la base de données avec requête préparée
    query = "SELECT * FROM users WHERE username = ?"
    user = database.execute(query, (username,))

    # Vérification du mot de passe avec bcrypt
    if user and bcrypt.checkpw(password.encode('utf-8'), user.password_hash):
        session['user_id'] = user.id
        return "Bienvenue !"
    else:
        return "Identifiants incorrects"
```

Version B

```python
@app.route('/login', methods=['POST'])
def login():
    username = request.form['username']
    password = request.form['password']

    # Recherche dans la base de données avec requête préparée
    query = "SELECT * FROM users WHERE username = ?"
    user = database.execute(query, (username,))

    # Vérification du mot de passe
    if user and user.password == password:
        session['user_id'] = user.id
        return "Bienvenue !"
    else:
        return "Identifiants incorrects"
```

Version C

```python
import hashlib

@app.route('/login', methods=['POST'])
def login():
    username = request.form['username']
    password = request.form['password']

    # Hash du mot de passe avec MD5
    password_hash = hashlib.md5(password.encode()).hexdigest()

    # Recherche dans la base de données
    query = f"SELECT * FROM users WHERE username='{username}' AND
password='{password_hash}'"
    user = database.execute(query)
```

```
    if user:
        return "Bienvenue !"
    else:
        return "Erreur de connexion"
```

Je choisis la version : _____ (A, B ou C) **(3 points)**

Justification de mon choix (expliquez pourquoi cette version corrige TOUS les problèmes) : **(2 points)**

Pourquoi les autres versions ne sont PAS correctes : **(1 point)**

Version ____ n'est pas bonne car : (0.5 pt)

Version ____ n'est pas bonne car : (0.5 pt)

Exercice 3 : Cet exercice est au choix (3a ou 3b)

NB : Veuillez faire un choix parmi ces deux propositions et traitez l'exercice choisi

☐ Exercice 3-a: Sécuriser une inscription (13 points)

Contexte : Vous créez une page d'inscription simple avec email et mot de passe.

Questions :

a) (5 points) Quelles vérifications devez-vous faire sur le mot de passe ? Citez 3 critères importants.

Exemple : Le mot de passe doit contenir au moins X caractères.

Votre réponse :

Critère 1 : **(3 points)**

Critère 2 : **(2 points)**

Critère 3 : **(2 points)**

b) (4 points) Comment devez-vous stocker le mot de passe dans la base de données ?

- Quel algorithme utiliser ?
- Pourquoi PAS en clair ?

Votre réponse :

Algorithme à utiliser : **(2 points)**

Pourquoi PAS stocker en clair : **(2 points)**

c) (4 points) Décrivez en 3-4 étapes simples comment un utilisateur se connecte de manière sécurisée.

Exemple :

1. L'utilisateur saisit email + mot de passe
2. ...
3. ...
4. …

Votre réponse : (1 point par étape)

Étape 1 :

Étape 2 :

Étape 3 :

Étape 4 (optionnelle) :

☐ Exercice 3b : Gestion de versions avec Git (13 points)

Contexte : Vous travaillez dans une équipe de 4 développeurs sur un projet web. Le code source est hébergé sur GitHub. Vous devez ajouter une nouvelle fonctionnalité : un **système d'envoi d'emails automatiques** pour les rappels.

Questions :

a) (5 points) Workflow Git complet

Vous commencez votre journée de travail. Décrivez **5 étapes avec les commandes Git** pour développer cette nouvelle fonctionnalité de manière professionnelle.

Votre réponse :

Étape 1 : Mise à jour du code **(1 point)**

Commande(s) : _____ (0.5 pt)

_____

Explication : _____ (0.5 pt)

_____

_____

Étape 2 : Création d'une branche dédiée **(1 point)**

Commande(s) : _____ (0.5 pt)

_____

Explication : _____ (0.5 pt)

_____

_____

Étape 3 : Développement et sauvegarde locale **(1 point)**

Commande(s) : _____ (0.5 pt)

_____

_____

Explication : _____ (0.5 pt)

_____

_____

Étape 4 : Partage du code avec l'équipe **(1 point)**

Commande(s) : _____ (0.5 pt)

_____

Explication : _____ (0.5 pt)

_____

_____

Étape 5 : Intégration dans le projet principale **(1 point)**

Commande(s) : _____ (0.5 pt)

_____

Explication : _____ (0.5 pt)

_____

_____

b) (4 points) Comprendre les commandes Git

Complétez le tableau suivant pour expliquer la différence entre ces commandes :

Commande	Où ça se passe ?	À quoi ça sert ?	Exemple concret
git add fichier.py			
git commit -m "message"			
git push origin branche			

Votre réponse :

git add fichier.py : **(1.5 points)**

Où ça se passe : _____

À quoi ça sert : _____

_____

Exemple concret :"Je viens de modifier des fichiers, donc je peux _____

_____"

_____

git commit -m "message" : **(1.5 points)**

Où ça se passe : _____

À quoi ça sert : _____

_____

Exemple concret : "Je viens de finir une fonctionnalité et je veux _____

_____"

---

git push origin branche : **(1 point)**

Où ça se passe : _____

À quoi ça sert : _____

Exemple concret :"Je veux que mon équipe puisse voir mon travail, donc je _____

_____"

---

c) (4 points) Que faire dans ces situations ?

Situation 1 (1 point) : Vous avez écrit un mauvais message dans votre dernier commit (que vous n'avez pas encore poussé sur GitHub). Comment le corriger ?

Commande : _____

Situation 2 (1 point) : Votre collègue a ajouté du code sur GitHub. Comment récupérer son travail ?

Commande : _____

Situation 3 (1 point) : Vous voulez créer une nouvelle branche "feature-notification". Quelle commande ?

Commande : _____

Situation 4 (1 point) : Vous voulez voir l'historique de tous les commits du projet. Quelle commande ?

Commande : _____

<u>Aide - Mémoire Git:</u>

Local vs Distant (la différence clé)

Local (votre PC)	Distant (GitHub)
`git add`	`git push`
`git commit`	`git pull`
`git branch`	-
`git checkout`	-

Règle simple : Si la commande contient "push" ou "pull", ça communique avec GitHub!

Commandes de base :

- `git branch nom`
- `git checkout nom`
- `git add .`
- `git commit -m "message"`
- `git push`
- `git pull`
- `git log` → voir l'historique
- `git commit --amend` → modifier le dernier commit

GREEN UP ACADEMY

BARÈME RÉCAPITULATIF

Partie	Points	Contenu
Partie 1	**30**	6 questions × 5 points
Partie 2	**30**	20 QCM × 1.5 points
Partie 3	**40**	3 exercices (15 + 12 + 13) points
TOTAL	**100**	

GRILLE DE NOTATION

Points	Note	Appréciation
90-100	18-20	Excellent - Très bien maîtrisé
75-89	15-17	Bien - Bonne compréhension
60-74	12-14	Assez bien - Bases correctes
50-59	10-11	Passable - À améliorer
< 50	< 10	Insuffisant - Revoir le cours

CONSEILS PRATIQUES

Comment répondre :

- Soyez **simple et direct**
- Utilisez des **phrases courtes**
- Donnez des **exemples concrets**
- Si vous ne savez pas : écrivez ce que vous savez, c'est mieux que rien !

Points importants à retenir :

- Sprint = 2 semaines en général
- Story Points ≠ Heures
- Toujours hasher les mots de passe (bcrypt)
- Requêtes préparées contre injection SQL
- HTTPS pour protéger les données en transit
- Git commit = local, Git push = distant
- Toujours créer une branche pour une nouvelle fonctionnalité

Bonne chance !